



Threat Modelling NEMU IPB

Perancangan dan Implementasi Protokol Keamanan AAA pada Sistem Informasi NEMU IPB

Kelompok 7

Salma Putri Hanifah	G6401231010
Marsya Hasna Khairunnisa	G6401231015
Lathiifa Zahira Yahya	G6401231154

1. Tujuan

Dokumen ini memetakan ancaman keamanan terhadap sistem **NEMU IPB** pada kondisi awal, yaitu kondisi sistem yang diasumsikan belum memiliki kontrol keamanan seperti:

- JWT authentication
- Role-based authorization
- Accounting/audit logging
- Password hashing yang kuat
- Enkripsi data sensitif
- Digital signature pada dokumen serah terima

Hasil dari *threat modeling* ini digunakan untuk menurunkan kebutuhan keamanan (*security requirements*) yang akan diimplementasikan pada tahap pengembangan berikutnya.

2. Ruang Lingkup

Termasuk dalam Threat Modeling:

1. Proses login dan pengelolaan akun pengguna (mahasiswa/civitas).
2. Pelaporan barang hilang oleh pengguna.
3. Pengelolaan barang temuan oleh admin/petugas.
4. Proses pengajuan klaim barang oleh pelapor.
5. Verifikasi klaim dan penerbitan dokumen serah terima oleh admin.
6. Penyimpanan data sensitif, bukti foto, dan dokumen serah terima.

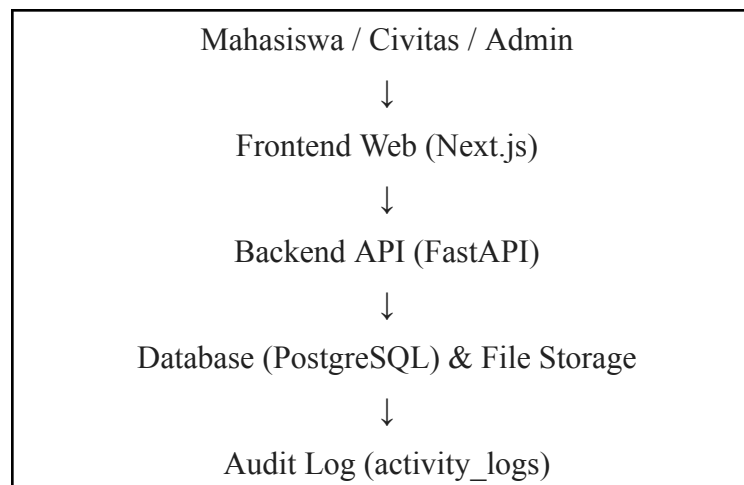
7. Log aktivitas dan bukti audit.

Tidak Termasuk dalam Threat Modeling:

- Keamanan fisik server dan perangkat loket.
- Serangan terhadap perangkat pribadi pengguna.
- Audit keamanan pihak ketiga.
- Integrasi SSO institusi secara penuh.

3. Data Flow Overview

Alur Data Utama NEMU IPB:



Titik yang Perlu Diamankan:

1. Komunikasi pengguna dengan frontend.
2. Request dari frontend ke backend (menggunakan HTTPS).
3. Validasi identitas dan hak akses pada backend.
4. Penyimpanan data pada database (enkripsi data sensitif).
5. Penyimpanan bukti foto dan dokumen serah terima.
6. Pencatatan aktivitas penting pada audit log (*non-modifiable*).

4. Rancangan Alur Keamanan

4.1 Alur Login

1. Pengguna memasukkan username dan password.
2. Frontend mengirim request ke endpoint login.
3. Backend membentuk email dari username dan mencari data user.

4. Backend memverifikasi password terhadap password hash.
5. Jika valid, backend membuat *JWT* berisi identitas dan role.
6. Frontend menggunakan token untuk mengakses endpoint terlindungi.
7. Setiap request divalidasi melalui dependency autentikasi.

4.2 Alur Akses Admin

1. Admin login dan menerima token.
2. Admin mengakses fitur verifikasi laporan, klaim, atau ekspor data.
3. Backend memvalidasi token.
4. Backend memeriksa role pengguna.
5. Jika role adalah admin, request diproses.
6. Jika bukan admin, request ditolak.
7. Aktivitas admin dicatat ke log.

4.3 Alur Klaim dan Serah Terima

1. Pengguna login dan mengajukan klaim barang.
2. Sistem menyimpan data klaim dengan status awal.
3. Admin memverifikasi klaim.
4. Jika klaim disetujui, sistem membuat dokumen serah terima.
5. Sistem menghasilkan hash dokumen menggunakan *SHA-256*.
6. Sistem menandatangani hash dokumen menggunakan *RSA*.
7. Sistem menyimpan dokumen, hash, digital signature, dan public key.
8. Dokumen dapat diverifikasi kembali melalui endpoint verifikasi.

5. Identifikasi Threat Actor

Threat Actor	Motivasi	Contoh Ancaman
Pengguna tidak terautentikasi	Mengakses data laporan/klaim tanpa akun	Mencoba mengakses endpoint API secara langsung, brute force login
Mahasiswa/Civitas berbahaya	Mengakses data laporan pengguna lain atau memanipulasi klaim	Mengubah parameter ID pada request klaim barang
Admin terkompromi	Menyalahgunakan akses verifikasi dan log	Memanipulasi status klaim secara ilegal atau menghapus log aktivitas

Penyerang eksternal	Mencuri data berharga atau mengambil alih akun pengguna	Credential stuffing, token theft, SQL injection
Anggota tim yang lalai	Membocorkan secret key atau konfigurasi sistem	Tidak sengaja melakukan commit berkas <code>.env</code> , private key, atau password database ke repositori publik

6. STRIDE Threat Analysis

6.1 Spoofing (Penyamaran Identitas)

Spoofing terjadi ketika penyerang berpura-pura menjadi pengguna lain atau admin sistem.

Ancaman	Dampak	Mitigasi
Login tanpa validasi kredensial yang kuat	Akun pengguna atau admin dapat diambil alih oleh pihak tidak bertanggung jawab	Penerapan password hashing yang kuat (bcrypt), rate limiting, dan validasi login berlapis
Token JWT mudah dipalsukan atau masa kedaluwarsa diabaikan	Penyerang dapat membuat token palsu dan bebas mengakses endpoint protected	Menggunakan JWT signed token dengan algoritma asimetris, serta memvalidasi <code>expire_time</code> secara ketat
Penyerang memalsukan identitas saat melakukan klaim barang	Barang hilang diserahkan kepada orang yang salah (bukan pemilik asli)	Melakukan verifikasi identitas fisik berlapis oleh admin sebelum klaim disetujui

6.2 Tampering (Modifikasi Data Tanpa Izin)

Tampering terjadi ketika data laporan, klaim, atau dokumen serah terima diubah oleh pihak yang tidak berhak.

Ancaman	Dampak	Mitigasi
---------	--------	----------

Pengguna memodifikasi isi laporan barang atau data klaim melalui request API langsung	Terjadi manipulasi status barang dan pemalsuan informasi temuan	Validasi data yang ketat di sisi server (FastAPI) serta implementasi <i>ownership check</i>
Dokumen bukti serah terima diubah setelah diterbitkan	Pemalsuan bukti penyerahan barang hilang yang sah	Implementasi hash SHA-256 dan tanda tangan digital menggunakan RSA pada dokumen serah terima
Request API dimodifikasi untuk mengubah ID laporan atau status klaim	Terjadi akses horizontal tidak sah antar pengguna	Implementasi backend authorization pada setiap endpoint serta penerapan RBAC yang ketat
Data penting pada database diubah tanpa adanya bukti perubahan	Sulit dibuktikan siapa pelaku di balik perubahan ilegal tersebut	Penerapan audit logging komprehensif pada tabel <code>activity_logs</code> yang bersifat <i>non-modifiable</i>

6.3 Repudiation (Penyangkalan Aktivitas)

Repudiation terjadi ketika pengguna atau admin menyangkal aktivitas yang pernah mereka lakukan di dalam sistem.

Ancaman	Dampak	Mitigasi
Pengguna mengklaim tidak pernah menerima barang kembali setelah serah terima	Menimbulkan ketidakpastian hukum dan hilangnya akuntabilitas transaksi	Dokumen serah terima ditandatangani secara digital oleh kedua belah pihak (<i>RSA Digital Sign</i>)
Admin menyangkal telah melakukan verifikasi terhadap klaim barang tertentu	Konflik internal dan investigasi insiden keamanan menjadi sangat sulit	Penyusunan log aktivitas admin yang <i>non-modifiable</i> ; setiap aksi admin dicatat lengkap
Transaksi klaim barang tidak memiliki tanda tangan digital yang sah	Aspek non-repudiation sistem menjadi sangat lemah	Penerapan digital signature untuk setiap aksi penting (persetujuan klaim dan serah

		terima)
--	--	---------

6.4 Information Disclosure (Kebocoran Informasi)

Information Disclosure terjadi ketika data sensitif bocor kepada pihak yang tidak memiliki hak akses.

Ancaman	Dampak	Mitigasi
Data laporan dan identitas lengkap pelapor dapat diakses secara publik	Terjadi pelanggaran privasi dan kebocoran data pribadi (terkait UU PDP)	Penerapan <i>authorization check</i> dan membatasi akses file secara terlindungi (<i>protected file access</i>)
Token JWT mengandung data sensitif di dalam payload-nya	Kebocoran identitas dan role penting pengguna	Menyembunyikan data rahasia dari payload JWT serta menggunakan HTTPS untuk enkripsi transmisi data
Password pengguna disimpan dalam format tidak aman (plaintext)	Jika database bocor, penyerang langsung mengkompromikan banyak akun sekaligus	Menggunakan mekanisme hashing dengan garam (<i>salting</i>) menggunakan algoritma bcrypt
Secret key dan konfigurasi sensitif <code>.env</code> masuk ke repositori kode	Token JWT atau sistem enkripsi database dapat dikompromikan sepenuhnya	Menggunakan <code>.gitignore</code> , variabel lingkungan (<i>environment variables</i>), dan rotasi secret key berkala
Log aktivitas sistem mencatat informasi yang terlalu sensitif	Kebocoran data internal melalui file log	Memastikan log hanya mencatat metadata aman; password, token, dan private key dilarang dicatat

6.5 Denial of Service (Gangguan Layanan)

Denial of Service terjadi ketika layanan dibuat tidak tersedia atau tidak responsif bagi pengguna sah.

Ancaman	Dampak	Mitigasi
---------	--------	----------

Serangan brute force massal pada endpoint login	Server kehabisan resource dan akun pengguna rentan terkunci/ditargetkan	Penerapan <i>rate limiting</i> pada endpoint krusial (terutama login) beserta strategi <i>lockout</i> sementara
Pengguna mengunggah bukti foto barang temuan dengan ukuran yang sangat besar	Kapasitas penyimpanan (<i>storage</i>) habis atau bandwidth server terkuras habis	Melakukan validasi ukuran file maksimal dan tipe file yang diizinkan di sisi backend
Request API yang masif pada endpoint pencarian barang dan pembuatan laporan	Server backend menjadi lambat atau crash akibat <i>resource exhaustion</i>	Menerapkan mekanisme <i>throttling</i> , optimasi query database (SQLAlchemy), serta pemantauan (<i>monitoring</i>)

6.6 Elevation of Privilege (Peningkatan Hak Akses)

Elevation of Privilege terjadi ketika pengguna memperoleh hak akses yang lebih tinggi dari hak akses sah mereka.

Ancaman	Dampak	Mitigasi
Pengguna umum berhasil mengakses endpoint verifikasi atau administrasi	Pengguna biasa dapat memverifikasi klaim barang mereka sendiri	Penerapan RBAC yang ketat di backend (misalnya menggunakan fungsi <code>dependency injection</code> <code>ensure_admin</code> di FastAPI)
Role pengguna diubah melalui manipulasi parameter request atau modifikasi token	Pengguna dapat meningkatkan hak akses mereka sendiri menjadi admin	Pengaturan role hanya boleh dikelola oleh backend; server wajib re-check status ke database berdasarkan User ID dalam JWT
Pengguna biasa berhasil mengakses atau mengubah isi log aktivitas	Terjadi manipulasi bukti audit sehingga akuntabilitas sistem hilang	Akses menu log dibatasi khusus untuk admin utama; log didesain agar bersifat <i>append-only</i> (<i>non-modifiable</i>)

7. Risk Matrix

Skala Penilaian:

- **Likelihood:** Low, Medium, High
- **Impact:** Low, Medium, High
- **Risk Level:** Low, Medium, High, Critical

ID	Risiko	Likelihood	Impact	Level	Mitigasi Prioritas
R1	Akun diambil alih karena mekanisme <i>authentication</i> lemah	High	High	Critical	Password hashing (bcrypt), JWT signature, rate limiting
R2	Pengguna mengakses laporan atau klaim milik pengguna lain	Medium	High	High	Penerapan <i>ownership check</i> dan RBAC ketat
R3	Dokumen bukti serah terima barang dipalsukan atau dimanipulasi	Low	High	High	Integrasi hash SHA-256 dan RSA digital signature
R4	Status klaim barang dimanipulasi secara ilegal oleh pengguna biasa	Medium	High	High	Validasi role ketat, pencatatan audit log, digital signature

R5	Seluruh password pengguna bocor dari database akibat peretasan	Medium	High	High	Penerapan hashing & salting wajib (bcrypt)
R6	Data identitas pelapor dan bukti foto dokumen sensitif bocor ke publik	Medium	High	High	Penerapan <i>protected file access</i> dan enkripsi data sensitif
R7	Aktivitas mencurigakan dari admin tidak terlacak	Medium	Medium	Medium	Sistem <i>accounting / audit logging</i> yang bersifat <i>non-modifiable</i>
R8	Secret key atau kredensial database tidak sengaja terkomit ke repositori git	Medium	High	High	Penerapan <code>.gitignore</code> , konfigurasi env, dan rotasi secret
R9	Serangan brute force pada halaman login	High	Medium	High	Pembatasan limit request (rate limiting) dan monitoring
R10	Pengguna menyangkal telah menerima kembali barang yang hilang	Medium	Medium	Medium	Tanda tangan digital RSA dan penyusunan bukti audit trail

8. Security Requirement Analysis

Berdasarkan hasil analisis ancaman di atas, dirumuskan kebutuhan keamanan (*security*

requirements) untuk sistem NEMU IPB sebagai berikut:

8.1 Authentication Requirements

- Sistem wajib memverifikasi identitas pengguna secara valid sebelum memberikan akses ke fitur-fitur terproteksi (*protected routes*).
- Password pengguna dilarang keras disimpan dalam bentuk plaintext; wajib menggunakan hashing + salting dengan standard industri yang aman (seperti bcrypt).
- Token autentikasi berbasis JWT harus ditandatangani (*signed*) secara aman, memiliki waktu kedaluwarsa (*expiration time*), dan divalidasi dengan ketat di sisi server.
- Setiap kegagalan login wajib dicatat dalam log keamanan dan dibatasi frekuensinya (*rate limiting*) guna mencegah brute force attack.

8.2 Authorization Requirements

- Sistem wajib menerapkan *Role-Based Access Control* (RBAC) yang tegas untuk membedakan hak akses antara pengguna umum (mahasiswa/civitas) dan administrator.
- Sistem harus melakukan *ownership check* secara konsisten di sisi backend untuk memastikan pengguna hanya bisa melihat, mengedit, atau mengklaim data milik mereka sendiri.
- Penentuan role dan hak akses (*permission*) tidak boleh mempercayai input langsung dari client tanpa divalidasi ulang oleh server berdasarkan database.
- Semua endpoint sensitif (seperti verifikasi klaim barang, pengubahan log, atau penghapusan data) wajib menolak request yang tidak memiliki otorisasi yang sesuai.

8.3 Accounting Requirements

- Sistem harus mencatat secara otomatis seluruh aktivitas penting yang dilakukan oleh pengguna maupun administrator.
- Log aktivitas wajib mencatat parameter minimal: pelaku aksi (*actor*), jenis aksi (*action*), target data (*resource*), waktu kejadian (*timestamp*), status keberhasilan, serta detail log yang aman.
- Log dilarang keras mencatat data kredensial sensitif seperti password, token aktif, maupun private key milik pengguna atau sistem.
- Setiap aktivitas administrasi, terutama perubahan status klaim barang, wajib dijadikan prioritas utama dalam pencatatan log.

8.4 Data Protection Requirements

- Seluruh data yang disimpan ke dalam sistem harus diklasifikasikan berdasarkan tingkat sensitivitasnya terlebih dahulu.

- Dokumen digital serta data pribadi pelapor wajib dilindungi menggunakan kontrol akses yang memadai dan/atau menggunakan metode enkripsi.
- Seluruh rahasia sistem (*secret keys*, password database, credential API) wajib disimpan pada berkas konfigurasi lingkungan (*environment variables* atau secret manager), bukan ditulis keras (*hardcoded*) di dalam source code aplikasi.

8.5 Integrity and Non-Repudiation Requirements

- Setiap perubahan data penting pada sistem harus dapat diverifikasi integritasnya agar tidak bisa dimanipulasi secara diam-diam.
- Mekanisme tanda tangan digital (*Digital Signature* berbasis RSA) harus diimplementasikan pada berkas dokumen serah terima digital guna memberikan bukti hukum yang kuat serta mencegah penyangkalan (*non-repudiation*).
- Penggunaan fungsi hash SHA-256 diimplementasikan untuk menjamin integritas fisik file dokumen setelah diterbitkan agar tidak bisa dimodifikasi di kemudian hari.
- Audit log harus secara aktif memantau dan mencatat hasil dari setiap aksi krusial serta status verifikasi klaim barang.

9. Kesimpulan

Hasil *threat modeling* ini menunjukkan bahwa risiko paling kritis pada sistem NEMU IPB berkaitan dengan potensi pengambilalihan akun pengguna, akses data ilegal lintas akun (*horizontal privilege escalation*), manipulasi berkas serah terima, kebocoran privasi pelapor (UU PDP), serta ketiadaan rekaman jejak aktivitas audit yang valid.

Oleh sebab itu, integrasi prinsip **AAA Security (Authentication, Authorization, Accounting)** yang disandingkan dengan mekanisme **Digital Signature** dan **Enkripsi Data** harus menjadi fokus utama tim pengembang sebelum meluncurkan sistem NEMU IPB sebagai platform resmi pengelolaan barang hilang (*lost and found*) di lingkungan civitas akademika IPB University.